

SUPPLY CHAIN VULNERABILITY & DEPENDENCY AUDIT REPORT

Project: Empros | Sovereign AI SOC (Agentic Swarm)
Scope: Rust Microservices, Shared Libraries, Middleware ETL Layer
Date: May 30, 2026

STATUS: REMEDIATED & HARDENED

I. Executive Summary

This report covers the supply chain audit conducted on **May 30, 2026** — ten days after the initial remediation documented in `Empros_Supply_Chain_Report(Rust).pdf` (May 20, 2026). The primary driver for this audit cycle was the architectural consolidation of the middleware ETL layer into the root Rust workspace, which brought **seven previously unaudited crates** into scope for the first time.

New findings from expanded scope: 4 findings — 3 CVEs and 1 unsound advisory — all rooted in a single transitive chain through `tiberius 0.12.3`, the Microsoft SQL Server driver used by `worker_sql`.

Remediation status: These 4 findings **cannot be resolved upstream** at this time. `tiberius 0.13` does not exist on `crates.io` (latest available: `0.12.3`). All 4 advisories are formally acknowledged in `.cargo/audit.toml` and classified as **accepted risk** with documented justification. They are excluded from CI audit failure gates while the upstream library matures.

Additionally: A silent `async-nats` version regression in the middleware workspace (`0.46` vs the remediated `0.48`) has been corrected through workspace consolidation.

II. Architectural Changes Since May 20 Audit

2.1 Single Workspace Consolidation

The middleware layer (`middleware/Cargo.toml`) was operating as a **separate, independent Rust workspace** with its own dependency table carrying different — and in one case insecure — version pins than the root workspace:

Dependency	Root (May 20)	Middleware (May 20)	Risk
async-nats	0.48 (patched)	0.46 (vulnerable)	RUSTSEC-2026-{0049,0098,0099,0104}
tokio	1.44	1.52	Version drift only
metrics-exporter-prometheus	0.16	0.18	Version drift only

The `async-nats` 0.46 drift was a **silent security regression**: all middleware crates were running a version carrying the `rustls-webpki` CVEs remediated in the May 20 report. This was invisible because the middleware workspace audit was failing at manifest resolution (wrong member path `lib_etl` vs `src/lib_etl`).

Resolution: `middleware/Cargo.toml` deleted. All 7 middleware crates are now members of the root workspace and inherit all security pins including `async-nats = "0.48"`.

2.2 Unified Dependency Control

Every service and library `Cargo.toml` now uses `{ workspace = true }` for all dependencies. Version pins are maintained exclusively in the root `[workspace.dependencies]` table, enforcing a **single Cargo.lock** for all 15 crates.

2.3 Formal Advisory Acknowledgement (`.cargo/audit.toml`)

A `.cargo/audit.toml` configuration file has been introduced to formally document accepted-risk advisories with justification. This replaces ad-hoc ignore flags and ensures every suppressed advisory has a recorded reason and a re-evaluation trigger.

2.4 Audit Methodology Updated

The previous `audit.sh` ran each crate in isolation, excluding the workspace root. This approach caused middleware audits to fail silently. The new `audit.sh` mounts the full workspace and runs `cargo audit --config .cargo/audit.toml` once from the workspace root, scanning all 502 crate dependencies in a single pass.

III. New Findings — Accepted Risk (No Upstream Fix Available)

All four new findings trace to a single root: **tiberius 0.12.3**, the Microsoft SQL Server driver used by `worker_sql`. **tiberius 0.13 does not exist on crates.io** (candidate versions: 0.12.3, 0.12.2, 0.12.1 only). No upgrade path is available.

Findings 1-3: `rustls-webpki` 0.101.7 (Three CVEs)

Advisory	Title	Severity
RUSTSEC-2026-0098	Name constraints for URI names incorrectly accepted	High
RUSTSEC-2026-0099	Name constraints accepted for wildcard certificate names	High
RUSTSEC-2026-0104	Reachable panic in CRL parsing	Medium

Dependency chain:

```
worker_sql
+-- tiberius 0.12.3
    +-- tokio-rustls 0.24.1
        +-- rustls 0.21.12
            +-- rustls-webpki 0.101.7 <- VULNERABLE
```

Upstream status: Fix requires rustls-webpki >= 0.103.12, achievable only by upgrading tiberius to a version using rustls 0.23+. No such version of tiberius is published.

Risk context: worker_sql is the SQL Server destination worker, **disabled by default** (sql_enabled = false in production config). The TLS vulnerability in this chain is only reachable if the SQL destination is explicitly enabled and the server presents a crafted certificate. Exploitation requires an adversary-controlled SQL Server endpoint.

Verdict: Accepted Risk — Upstream Blocked. Tracked in .cargo/audit.toml

Finding 4: rand 0.7.3 — RUSTSEC-2026-0097 (Unsound)

Title: Rand is unsound with a custom logger using rand::rng()

Dependency chain:

```
worker_sql
+-- tiberius 0.12.3
    +-- winauth 0.0.4 <- Windows NTLM auth
        +-- rand 0.7.3 <- UNSOUND
```

Upstream status: winauth is removed in tiberius 0.13 (unreleased). No patch available in 0.12.x.

Risk context: The unsoundness requires a custom log implementation that calls rand::rng() during log formatting. The production deployment uses tracing with the standard tracing-subscriber backend, which does not trigger this path.

Verdict: Accepted Risk — Upstream Blocked. Tracked in .cargo/audit.toml

IV. Remediation Actions Summary

Change	Before	After	Effect
async-nats (middleware)	0.46 (regression)	0.48	RUSTSEC-2026-{0049,0098,0099,0104} resolved for all middleware crates
Middleware workspace	Isolated, failing audit	Unified under root	7 crates now audited; version drift eliminated
.cargo/audit.toml	None	Introduced	Tiberius chain + unmaintained crates formally documented
audit.sh	Per-service isolation	Single workspace root	Coverage gaps eliminated; CI gate now covers full graph

V. Residual Warnings — Accepted Risk (Full List)

All warnings are formally acknowledged in .cargo/audit.toml.

Crate	Advisory	Chain	Assessment
paste 1.0.15	RUSTSEC-2024-0436	parquet -> arrow-cast	Compile-time proc-macro. Zero runtime. No CVE. Upstream blocked.
rustls-pemfile 1.0.4	RUSTSEC-2025-0134	tiberius -> rustls-native-certs	No CVE. Blocked on tiberius 0.13 release.
rustls-pemfile 2.2.0	RUSTSEC-2025-0134	qdrant-client -> tonic 0.12	No CVE. Blocked on qdrant-client upgrading to tonic 0.13+.
rustls-webpki 0.101.7	RUSTSEC-2026-0098/0099/0104	tiberius -> rustls 0.21	High. Upstream blocked (no tiberius 0.13). worker_sql disabled by default.

Crate	Advisory	Chain	Assessment
rand 0.7.3	RUSTSEC-2026-0097	tiberius -> winauth	Medium. Upstream blocked. Custom logger path not triggered in production.

VI. Post-Consolidation Audit Coverage

Layer	Crates	Status
Shared Libraries	lib_siem_core, lib_etl, lib_middleware	Clean
Services — Sensor Layer	core_ingress, worker_qdrant, worker_s3_archive, worker_rules, worker_rlhf, worker_soar	Clean
Middleware — ETL Layer	middleware_ingress, worker_nexus, worker_splunk, worker_elastic, worker_sql	4 accepted warnings (tiberius chain, upstream blocked)
Integration Tests	nexus_integration_tests	Clean

Dependency coverage: 502 crates resolved across 15 workspace members (vs 433 crates / 7 members on May 20).

VII. Active Security Pins (root Cargo.toml)

Dependency	Pinned Version	Advisories Covered
async-nats	0.48	RUSTSEC-2026-{0049, 0098, 0099, 0104}
validator	0.20	RUSTSEC-2024-0421, RUSTSEC-2024-0370
object_store	0.11	RUSTSEC-2024-0358
parquet	58.3	RUSTSEC-2023-0086 (covers >=53 requirement)

Dependency	Pinned Version	Advisories Covered
tiberius	0.12	Pinned to latest available; upgrade to 0.13 when released

VIII. Conclusion

The May 30, 2026 audit cycle identified **4 new findings** (3 CVEs, 1 unsound advisory) introduced by expanding audit scope to include the previously-unaudited middleware ETL layer. All 4 trace to tiberius 0.12.3's outdated TLS stack. No upstream fix is available (tiberius 0.13 is unpublished). These are formally acknowledged as accepted risk in .cargo/audit.toml with documented justification and re-evaluation triggers.

A pre-existing security regression (async-nats 0.46 in middleware) was corrected through workspace consolidation, applying the 0.48 security pin uniformly across all 15 crates.

Combined with the May 20 findings, a total of **14 unique advisories** have been evaluated across both audit cycles: **8 remediated** by dependency upgrades, **6 accepted risk** (upstream-blocked with no available fix or active CVE).

Category	Count
Vulnerabilities remediated (May 20)	8
Unmaintained warnings — accepted (May 20)	2
Vulnerabilities accepted — upstream blocked (May 30, tiberius chain)	4
Unmaintained warnings — accepted (May 30, tiberius chain)	2
Total advisories evaluated	16

The Rust supply chain for Project Empros is in a **fully assessed and hardened state** for all actionable findings. Residual accepted-risk items are documented, monitored, and have defined re-evaluation triggers tied to upstream release events.